PROJECT PLAN

ISO 27001 IMPLEMENTATION

Document Classification	Internal
Version	1
Dated	25/10/26
Document Author	Aarti Narwade
Document Owner	NX Technologies

Note: NX Technologies is a fictional company. This document is a sample created for learning and portfolio purposes only.

REVISION HISTORY

VERSION	DATE	AUTHOR	DESCRIPTION
1	25/10/26	Aarti Narwade	Initial draft

DISTRIBUTION

NAME	TITLE
Aakash	CEO
Suvarna	CISO
Rahul	CTO

APPROVAL

NAME	POSITION	SIGNATURE	DATE
Aakash	CEO	Signed	27/10/26
Suvarna	CISO	Signed	27/10/26
Rahul	CTO	Signed	27/10/26

CONTENT

1. INTRODUCTION.....3
2. PROJECT OBJECTIVES.....3
3. PROJECT SCOPE.....4
4. KEY DELIVERABLES.....4
5. ROLES AND RESPONSIBILITIES.....5
6. PROJECT TIMELINE AND MILESTONES.....6
7. PROJECT RESOURCES.....7
8. BUDGET ESTIMATE.....8
9. RISK ASSESSMENT.....8
10. COMMUNICATION PLAN.....10
11. TRAINING AND AWARENESS.....10
12. MONITORING AND REVIEW.....11
13. APPROVAL AND SIGN-OFF.....13

1. INTRODUCTION

ISO/IEC 27001 is an international standard for information security. It was first published in 2005 and revised in 2013 and 2022, building upon the British Standard BS 7799. The standard sets out the requirements for establishing, implementing, maintaining and continually improving a robust Information Security Management System (ISMS).

NX Technologies is committed to implementing an ISO 27001:2022 compliant Information Security Management System (ISMS) to enhance the protection of sensitive information, ensure regulatory compliance, and strengthen its market position. This project plan outlines the steps, responsibilities, and timeline for successfully achieving ISO 27001 certification.

2. PROJECT OBJECTIVES

1. Achieve ISO 27001:2022 certification by the end of Month 13, with the target completion date of November 2027.

2. Protect sensitive information, including client data, proprietary training materials, and internal intellectual property.

3. Ensure compliance with relevant regulations, such as the GDPR, the Information Technology Act, 2000 and the Digital Personal Data Protection Act, 2023.

4. Enhance the company's market position by leveraging ISO 27001 certification.

5. Establish information security governance and increase awareness of information security principles across the NX Technologies team (target: 95% training completion).

3. PROJECT SCOPE

In-Scope:

- Operations at the Mumbai headquarters.
- Departments: IT, HR, Finance, Operations, and other departments handling sensitive information.
- Technology infrastructure, including the company website, cloud-based CRM system, and servers hosted in third-party data centers.
- Information assets: Client data, proprietary training materials, and internal intellectual property.
- Interfaces and dependencies: third-party Applications and cloud providers, key suppliers, and remote working arrangements.

Out-of-Scope:

- Personal devices of employees not used for business purposes (personal devices used for business purposes are in scope).
- Business units and locations outside the Mumbai headquarters (to be reviewed after initial certification), other than remote working and client-site work by in-scope staff.

4. KEY DELIVERABLES

1. ISMS Policies and Procedures.

2. Risk Assessment and Treatment Plan.

3. Statement of Applicability (SoA).

4. Employee Training and Awareness Program.

5. Internal Audit Reports and Management Review Minutes.

6. ISO 27001:2022 Certification.

5. ROLES AND RESPONSIBILITIES

- **Project Sponsor: Aakash,** CEO - Provide strategic direction and ensure alignment with business goals.

- **Project Manager: Suvarna,** CISO - Oversee the project, manage resources, and ensure timely delivery.

- **Chief Technology Officer (Rahul, CTO) -** Oversee the organizations technical infrastructure and ensuring that technical operations align with established information security rules.

- **ISMS Team: Naresh (Technical Lead),** Suresh (Implementation Lead) and Shankar (Internal Auditor) develop policies, conduct risk assessments, and implement controls.

- **Department Heads:** Ensure department-specific compliance with ISMS policies.

- **External Consultant:** Provide expertise and guidance on ISO 27001:2022 implementation.

- **Employees:** Participate in training and adhere to ISMS policies.

6. PROJECT TIMELINE AND MILESTONES

Phase	Duration	Activities
Phase 1: Project Initiation	Month 1	• Secure management approval and allocate resources. • Form the project team and develop the project charter.
Phase 2: Gap Analysis and Scoping	Months 2-3	• Conduct a gap analysis to assess current security measures against ISO 27001 requirements. • Confirm the ISMS scope and identify interfaces and dependencies.
Phase 3: ISMS Development	Months 4-7	• Conduct the risk assessment and prepare the Risk Treatment Plan. • Prepare the Statement of Applicability. • Develop and document information security policies, procedures, and controls.
Phase 4: Implementation and Training	Months 8-10	• Roll out the ISMS across the organization. • Conduct employee training sessions. • Engage an accredited certification body by Month 8 and schedule the Stage 1 and Stage 2 certification audits.
Phase 5: Internal Audit and Management Review	Month 11	• Conduct an internal audit and prepare a report for management review. • Hold the management review and close internal audit

		findings.
Phase 6: Certification Audit	Months 12-13	• Stage 1 audit (documentation review) in Month 12. • Stage 2 audit (implementation and effectiveness) in Month 13. • Address any nonconformities identified by the certification body and obtain certification upon successful completion of the certification process.

7 . PROJECT RESOURCES

1. Human Resources

Name	Role	Period Available	Commitment
Suvarna	Project Manager	13 months (Months 1-13)	5 days per week
Naresh	Technical Lead	10 months (Months 2-11)	5 days per week
Suresh	Implementation Lead	7 months (Months 4-10)	4 days per week
Shankar	Internal Auditor	2 months (Months 11-12)	3 days per week

2. Financial Resources

Resource	Amount Available	Availability
Capital Budget	$100,000	FY 2026-27 to FY 2027-28
Revenue Budget	$60,000 per annum	Ongoing

Contingency Fund	$10,000	As needed

8. BUDGET ESTIMATE

Initial Costs:

- **ISO 27001 Standard Purchase:** $1,500
- **Consultancy Fees:** $30,000
- **Training and Awareness Programs:** $10,000
- **Technology Upgrades:** $20,000
- **Penetration Testing and Vulnerability Assessment:** $5,000
- **Certification Audit (Stage 1 and Stage 2):** $15,000
- **Total Initial Cost:** $81,500 (all amounts in USD)

Ongoing Costs:

- **Maintenance of ISMS:** $5,000 annually
- **Internal Audits:** $3,000 annually
- **Continuous Training and Awareness:** $2,500 annually
- **Surveillance Audits (Years 2 and 3):** $7,500 annually
- **Recertification Costs (every 3 years):** $10,000
- **Total Annual Ongoing Cost:** $18,000 (excluding recertification)

9. RISK ASSESSMENT

Identified Risks:

1. Resource Allocation: Insufficient resources could delay implementation.

- **Mitigation:** Secure adequate budget and personnel from the start.

2. Non-Compliance: Failing to meet regulatory requirements could result in penalties.

- **Mitigation:** Regular compliance checks and audits.

3. Reputational Damage: Security breaches could damage client trust.

- **Mitigation:** Implement robust security measures and response plans.

4. Key-Person Dependency: Key team members share other duties and may become unavailable.

- **Mitigation:** Name a backup for each key role and keep project documentation current.

5. Certification Delay: Limited certification body availability could delay the Stage 1 and Stage 2 audits.

- **Mitigation:** Engage the certification body by Month 8 and book audit dates early.

10. COMMUNICATION PLAN

Internal Communication:

- **Monthly Progress Meetings:** Held by the Project Manager with the ISMS team to track progress and address any issues.
- **Quarterly Updates:** Provided to the executive management team to ensure alignment with business objectives.
- **Email Notifications:** Sent to all employees regarding training sessions, policy updates, and important project milestones.

External Communication:

- **Client Updates:** Periodic updates sent to clients, especially those in regulated industries, about progress towards certification.
- **Regulatory Bodies:** Any necessary communication with regulatory bodies to ensure compliance with legal requirements.

11. TRAINING AND AWARENESS

Employee Training Program:

- **Initial Training:** Conducted to educate employees on the importance of information security and their roles in the ISMS.

- **Ongoing Training:** Regular refresher courses and updates provided to keep employees informed of any changes to policies and procedures.

- **Specialized Training:** Focused sessions for IT and security staff on specific technical controls and incident response.

12. MONITORING AND REVIEW

- **Internal Audits:** Conducted periodically to assess the effectiveness of the ISMS and identify areas for improvement.
- **Management Reviews:** Held annually or as needed to review the ISMS, ensure alignment with business objectives, and make necessary adjustments.
- **Key Performance Indicators:** Training completion of at least 95%, internal audit findings closed within 30 days, and risk treatment actions completed on schedule.
- **Continuous Improvement:** A commitment to regularly updating and improving the ISMS to respond to emerging threats and business changes.

Information Security Deliverables Reference

REF	DELIVERABLE	DESCRIPTION
1	ISO 27001 Gap Assessment	Evaluates the current security posture at NX Technologies and identifies the actions required to meet ISO 27001 standards.
2	Set of information security policies	Establishes the information security policy framework for NX Technologies, outlining the essential security practices.
3	Statement of Applicability	Specifies which ISO 27001 requirements apply to NX Technologies and how they will be implemented.
4	Information Security Management System (ISMS) Policy	Details the operational framework of the ISMS, guiding how NX Technologies will manage and maintain

		information security.
5	Other ISMS documentation	A comprehensive set of documents that define the operational aspects of the ISMS at NX Technologies.
6	Procedures and controls to address risk	Documentation outlining the processes and controls to effectively manage and mitigate identified risks.
7	Risk Assessment and Treatment Process	Describes the methodology used for conducting risk assessments and implementing corresponding treatment plans.
8	Risk Assessment report(s)	Summarizes the findings of risk assessments, providing detailed analysis and results.
9	Risk Treatment Plan(s)	What will be done about the identified risks
10	Information security records	Minutes of meetings, reviews, visitor books and other information security-related records
11	Training and awareness programs	Combination of formal training for key staff and briefings for all other staff
12	Internal audit reports	Records the findings, evidence and nonconformities from internal audits of the ISMS.
13	Management review minutes	Records the management review of the ISMS, including decisions on improvements and resource needs.
14	ISO 27001:2022 certificate	Confirms that the ISMS has been independently audited and certified by an accredited certification body.

13. APPROVAL AND SIGN-OFF

This ISMS Project Plan is approved by the following:

- **CEO: Aakash,** Date: 27/10/26
- **CISO: Suvarna,** Date: 27/10/26
- **Project Manager: Suvarna,** Date: 27/10/26
- **Rahul (CTO)** Date: 27/10/26